

1.1.1 Fenyegetési tartományok

Mivel a szervezetek egyre növekvő számú kiberfenyegetéssel szembesülnek, kritikus fontosságú, hogy robusztus biztonsági megoldásokkal rendelkezzenek. De ahhoz, hogy megvédjék magukat, a szervezeteknek először tudniuk kell, hogy milyen sebezhetőségek léteznek a fenyegetési tartományaikban. A "fenyegetési tartomány" olyan ellenőrzési, hatósági vagy védelmi terület, amelyet a támadók kihasználhatnak a rendszerhez való hozzáféréshez.

A támadók sokféleképpen fedezhetik fel a sebezhetőségeket és kihasználhatják a tartományon belüli rendszereket.

Válassza ki a képet néhány példa megjelenítéséhez.



Attackers can exploit systems within a domain through:

- Direct, physical access to systems and networks.
- Wireless networking that extends beyond an organization's boundaries.
- Bluetooth or near-field communication (NFC) devices.
- Malicious email attachments.
- Less secure elements within an organization's supply chain.
- An organization's social media accounts.
- Removable media such as flash drives.
- Cloud-based applications.

A támadók a tartományon belüli rendszereket a következőkön keresztül használhatják ki:

- Közvetlen, fizikai hozzáférés a rendszerekhez és hálózatokhoz.
- Vezeték nélküli hálózat, amely túlmutat a szervezet határain.
- Bluetooth vagy közeli hatótávolságú kommunikációs (NFC) eszközök.

- Rosszindulatú e-mail mellékletek.
- Kevésbé biztonságos elemek a szervezet ellátási láncában.
- Egy szervezet közösségimédia-fiókjai.
- Cserélhető adathordozók, például flash meghajtók.
- Felhőalapú alkalmazások.

1.1.2 A kiberfenyegetések típusai

A kiberfenyegetések különböző kategóriákba sorolhatók. Ez lehetővé teszi a szervezetek számára, hogy felmérjék a fenyegetés bekövetkezésének valószínűségét, és megértsék a fenyegetés pénzügyi hatását, hogy rangsorolhassák biztonsági erőfeszítéseiket.

Válassza ki a címsorokat a kiberfenyegetésekre vonatkozó példákhoz ezekben a kategóriákban.

Szoftveres támadások

- Sikeres szolgáltatásmegtagadás (DoS támadás).
- Egy számítógépes vírus.



Szoftverhibák

- Szoftverhiba.
- Egy offline állapotba kerülő alkalmazás.
- Webhelyek közötti parancsfájl vagy érvénytelen fájlkiszolgáló-megosztás.



Szabotázs

- Egy jogosult felhasználó, aki sikeresen behatol a szervezet elsődleges adatbázisába, és feltöri azt.
- Egy szervezet weboldalának megrongálása.



Emberi hiba

- Véletlen adatbeviteli hibák.
- A tűzfal hibás konfigurációja.



Lopás

- Laptopokat vagy berendezéseket lopnak el egy nyitott szobából.



Hardverhibák

- A merevlemez összeomlik.



Közüzemi megszakítás

- Áramkimaradások.
- A sprinkler meghibásodásából eredő vízkár.



Természeti katasztrófák

- Súlyos viharok, például hurrikánok vagy tornádók.
- Földrengések.
- Árvizek.
- Tüzek.



1.1.3 Avatar

Ne feledje, hogy a kiberbűnözők repertoárja hatalmas és folyamatosan fejlődik. Néha a fenti taktikák közül kettőt vagy többet kombinálhatnak, hogy növeljék esélyeiket.

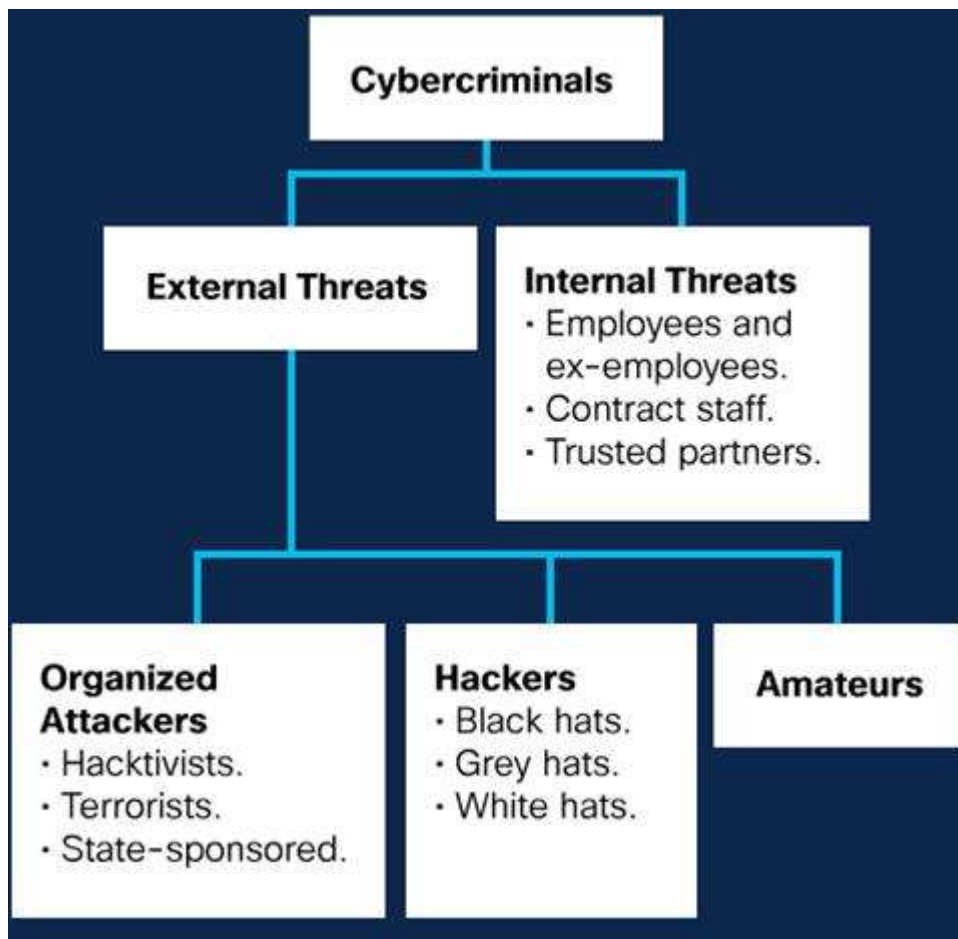
A kiberbiztonsági szakemberek feladata, hogy felhívják a figyelmet és felvilágosítsák a szervezet más embereit ezekről a taktikákról, hogy megakadályozzák, hogy ilyen támadások áldozatává váljanak.

1.1.4 Belső és külső fenyegetések

A fenyegetések a szervezeten belülről és kívülről is származhatnak, és a támadók értékes bizalmas információkhoz, például személyzeti nyilvántartásokhoz, szellemi tulajdonhoz és pénzügyi adatokhoz szeretnének hozzáférni.

A belső fenyegetéseket általában jelenlegi vagy korábbi alkalmazottak és más szerződéses partnerek hajtják végre, akik véletlenül vagy szándékosan rosszul kezelik a bizalmas adatokat, vagy veszélyeztetik a szerverek vagy hálózati infrastruktúra eszközök működését a fertőzött média csatlakoztatásával vagy rosszindulatú e-mailek vagy webhelyek elérésével.

A külső fenyegetés forrása általában amatőr vagy képzett támadókból származik, akik kihasználhatják a hálózati eszközök sebezhetőségeit, vagy social engineering technikákat, például trükköket használhatnak a szervezet belső erőforrásaihoz való hozzáféréshez.



1.1.5 Avatar

Tudtad, hogy a belső fenyegetések nagyobb károkat okozhatnak, mint a külső fenyegetések? Ennek az az oka, hogy a szervezeten belül dolgozó alkalmazottak vagy partnerek közvetlen hozzáféréssel rendelkeznek a telephelyéhez és az infrastruktúra-eszközökhöz. Belső ismeretekkel rendelkeznek a szervezet hálózataról, erőforrásairól és bizalmas adatairól, valamint a hatályos biztonsági ellenintézkedésekről is.

1.1.6 Ismerje meg a különbséget

Aggódik néhány lehetséges fenyegetés miatt, amelyekről nemrégiben számoltak be @Apollo. Mielőtt azonban foglalkozhatna velük, meg kell értenie, hogy a fenyegetések belső vagy külső forrásból származnak-e.

A kezdéshez válassza az Indítás lehetőséget.

**An employee was
tricked into giving out
confidential information
by someone pretending
to be their manager**

Egy alkalmazott
kipipálta az adakozást
bizalmas információk
valaki színleli
hogy a menedzserük legyél



1.1.7 Avatar

A kiberfenyegetések többféleképpen terjedhetnek, például magukon a felhasználókon, a hálózathoz csatlakoztatott eszközökön vagy nyilvános vagy magánfelhőben tárolt szolgáltatásokon keresztül. És ne feledkezzünk meg a fizikai támadás veszélyéről sem, ha nincsenek megfelelő biztonsági intézkedések.

Nézzük meg ezeket részletesebben.

1.1.8 Felhasználói fenyegetések és sebezhetőségek

A felhasználói tartomány magában foglal mindenkit, aki hozzáfér a szervezet információs rendszeréhez, beleértve az alkalmazottakat, az ügyfeleket és a szerződéses partnereket is. A felhasználókat gyakran tekintik az információbiztonsági rendszerek leggyengébb láncszemének, ami jelentős veszélyt jelent a szervezet adatainak bizalmas jellegére, integritására és rendelkezésre állására.

A fejlécek kiválasztásával további információkat jeleníthet meg a számos szervezetben előforduló

leggyakoribb felhasználói fenyegetésekről.

Nincs tudatosság a biztonsággal kapcsolatban

A felhasználóknak tisztában kell lenniük és meg kell érteniük a szervezet érzékeny adatait, biztonsági irányelveit és eljárásait, technológiáit és ellenintézkedéseit, amelyeket az információk és információs rendszerek védelme érdekében alkalmaznak.



Rosszul betartatott biztonsági irányelvek

Minden felhasználónak tisztában kell lennie a szervezet biztonsági szabályzataival, valamint a meg nem felelés következményeivel.



Adatlopás

A felhasználók által ellopott adatok jelentős pénzügyi veszélyt jelenthetnek a szervezetek számára, mind a hírnevük károsodása, mind az érzékeny információk nyilvánosságra hozatalával kapcsolatos jogi felelősség szempontjából.



Jogosulatlan letöltések és médiatartalmak

Számos hálózati és eszközfertőzés és támadás olyan felhasználókra vezethető vissza, akik jogosulatlan e-maileket, fényképeket, zenéket, játékokat, alkalmazásokat és videókat töltöttek le számítógépükre, hálózatukra vagy tárolóeszközükre, vagy jogosulatlan adathordozókat, például külső merevlemezeket és USB-meghajtókat használtak.



Jogosulatlan virtuális magánhálózatok (VPN-ek)

A VPN-ek elrejthetik a jogosulatlan információk ellopását, mivel a titoktartás védelmére általában használt titkosítás megakadályozhatja a hálózati rendszergazdát az adatátvitel nyomon követésében (kivéve, ha erre engedélyük van).



Jogosulatlan webhelyek

A jogosulatlan webhelyek elérése kockázatot jelenthet a felhasználó adataira és eszközeire, valamint magára a szervezetre nézve. Ezek a webhelyek gyakran arra kéri a felhasználókat, hogy töltsenek le rosszindulatú kódot vagy reklámprogramot tartalmazó szkripteket vagy bővítményeket. Ezen webhelyek némelyike akár felhasználói eszközöket, például kamerákat és alkalmazásokat is átvehet.



Rendszerek, alkalmazások vagy adatok megsemmisítése

A rendszerek, alkalmazások és adatok véletlen vagy szándékos megsemmisítése vagy sabotázsa komoly kockázatot jelent minden szervezet számára. Aktivisták, elégedetlen alkalmazottak vagy iparági versenytársak megpróbálják törölni az adatokat, megsemmisíteni vagy rosszul konfigurálni az eszközöket, hogy elérhetetlenné tegyék a szervezeti adatokat és információs rendszereket.



Mindig tartsa szem előtt, hogy nincsenek olyan technikai megoldások, ellenőrzések vagy ellenintézkedések, amelyek biztonságosabbá tennék az információs rendszereket, mint az ezeket a rendszereket használó emberek viselkedése és folyamatai.

1.1.9 Az eszközöket fenyegető veszélyek



- A bekapcsolt és felügyelet nélkül hagyott eszközök azzal a kockázattal járnak, hogy valaki jogosulatlanul hozzáfér a hálózati erőforrásokhoz.
- A fájlok, fényképek, zenék vagy videók megbízhatatlan forrásból történő letöltése

rosszindulatú kódok végrehajtásához vezethet az eszközökön.

- A kiberbűnözők gyakran kihasználják a szervezet eszközeire telepített szoftverek biztonsági réseit támadás indításához.
- A szervezet információbiztonsági csapatainak meg kell próbálniuk naprakészek maradni az új vírusok, férgek és egyéb rosszindulatú programok napi felfedezésével, amelyek veszélyt jelentenek az eszközeikre.



- A jogosulatlan USB-meghajtókat, CD-ket vagy DVD-ket behelyező felhasználók azt kockáztatják, hogy rosszindulatú programokat vezetnek be, vagy veszélyeztetik az eszközükön tárolt adatokat.
- A szervezet informatikai infrastruktúrájának védelmére vonatkozó szabályzatok vannak érvényben. A felhasználó súlyos következményekkel szembesülhet az ilyen irányelvek szándékos megsértése miatt.
- Az elavult hardver vagy szoftver használata sebezhetőbbé teszi a szervezet rendszereit és adatait a támadásokkal szemben.

1.1.10 A helyi hálózatot fenyegető veszélyek

A helyi hálózat (LAN) jellemzően ugyanazon a földrajzi területen található eszközök gyűjteménye, amelyeket kábelek (vezetékes) vagy rádióhullámok (vezeték nélküli) kötnek össze.

Mivel a felhasználók a LAN-tartományból férhetnek hozzá a szervezet rendszereihez, alkalmazásaihoz és adataihoz, kritikus fontosságú, hogy erős biztonsággal és szigorú hozzáférés-vezérléssel rendelkezzen.

Válassza ki a képet a helyi hálózatot fenyegető gyakori fenyegetések megjelenítéséhez.



Példák a LAN-t fenyegető veszélyekre:

- Jogosulatlan hozzáférés a kábelszekrényekhez, adatközpontokhoz és számítógéptermekekhez.
- Jogosulatlan hozzáférés a rendszerekhez, alkalmazásokhoz és adatokhoz.
- Hálózati operációs rendszer vagy szoftver biztonsági rései és frissítései.
- A szélhámoss felhasználók jogosulatlan hozzáférést kapnak a vezeték nélküli hálózatokhoz.
- Az átvitel alatt álló adatok kihasználása.
- A különböző hardverekkel vagy operációs rendszerekkel rendelkező LAN-kiszolgálók megnehezítik azok kezelését és hibaelhárítását.
- Jogosulatlan hálózati szondázás és portkeresés.
- Helytelenül konfigurált tűzfalak.

1.1.11 A magánfelhőt fenyegető veszélyek



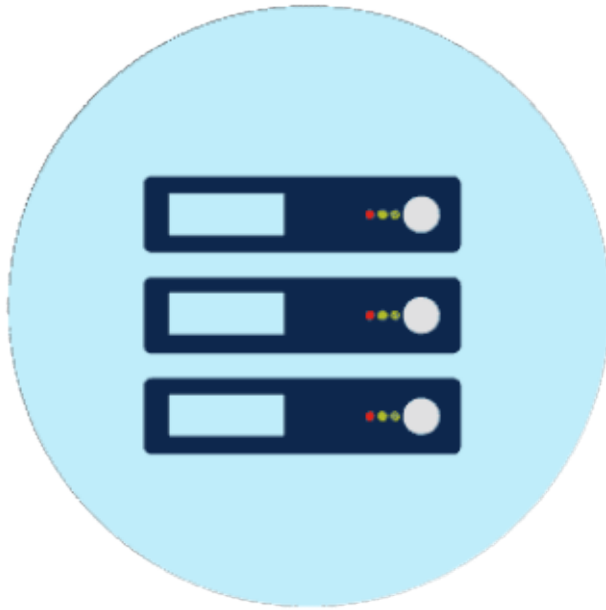
A magánfelhő tartomány magában foglal minden olyan privát szervert, erőforrást és informatikai infrastruktúrát, amely egyetlen szervezet tagjai számára elérhető az interneten keresztül. Bár sok szervezet úgy érzi, hogy adatai biztonságosabbak a magánfelhőben, ez a tartomány továbbra is jelentős biztonsági fenyegetést jelent, többek között:

- Jogosulatlan hálózati szondázás és portkeresés.
- Jogosulatlan hozzáférés az erőforrásokhoz.
- Router, tűzfal vagy hálózati eszköz operációs rendszerének vagy szoftverének biztonsági rései.
- Router, tűzfal vagy hálózati eszköz konfigurációs hibák.
- Távoli felhasználók hozzáférnek egy szervezet infrastruktúrájához és bizalmas adatokat töltenek le.

1.1.12 A nyilvános felhőt fenyegető veszélyek

Ahol egy magánfelhő-tartomány egyetlen szervezet számítási erőforrásait tárolja, a nyilvános felhőtartomány a felhő-, szolgáltatás- vagy internetszolgáltató által üzemeltetett, a nyilvánosság számára elérhető és a szervezetek között megosztott számítástechnikai szolgáltatások összessége. A nyilvános felhőszolgáltatásoknak három modellje van, amelyeket a szervezetek használhatnak.







1.1.13 Avatar

Míg a nyilvános felhőszolgáltatók biztonsági vezérlőket hajtanak végre a felhőkörnyezet védelme érdekében, a szervezetek felelősek a felhőben lévő saját erőforrásaik védelméért. Ezért a nyilvános felhőtartományt fenyegető leggyakoribb fenyegetések a következők:

- Adatvédelmi incidensek.
- Szellemi tulajdon elvesztése vagy ellopása.
- Feltört hitelesítő adatok vagy fiókeltérítés.
- Pszichológiai manipulációs támadások.
- Megfelelőség megsértése.

1.1.14 Mit gondolsz?

A fizikai fenyegetéseket gyakran figyelmen kívül hagyják a kiberbiztonság mérlegelésekor, de a fizikai biztonság valójában kritikus fontosságú, ha meg akarjuk akadályozni, hogy egy szervezet a kiberbűnözés áldozatává váljon.

Ezt szem előtt tartva szánjon néhány percet arra, hogy átgondolja a @Apollo irodáit fenyegető lehetséges fizikai fenyegetéseket.

Írjon néhány példát az alábbi mezőbe, majd válassza a Küldés lehetőséget. Ezután válassza a Válasz megjelenítése lehetőséget a szervezet fizikai létesítménytartományát fenyegető gyakori példák feltárásához, és hasonlítsa össze a választ.

200 karakter maradt

A szöveg mentésre került

Előterjeszt

1.1.15 Az alkalmazásokat fenyegető veszélyek

Az alkalmazástartomány magában foglalja a szervezet által a műveletek támogatására használt összes kritikus rendszert, alkalmazást és adatot. A szervezetek egyre gyakrabban helyeznek át olyan alkalmazásokat, mint az e-mail, a biztonsági felügyelet és az adatbázis-kezelés a nyilvános felhőbe.

Az alkalmazásokat fenyegető gyakori veszélyek a következők:

- Valaki, aki jogosulatlanul hozzáfér az adatközpontokhoz, számítógéptermekekhez, kábelszekrényekhez vagy rendszerekhez.
- Kiszolgáló leállása a karbantartási időszakok alatt.
- Hálózati operációs rendszer szoftvereinek biztonsági rései.
- Adatvesztés.
- Kliens-szerver vagy webalkalmazás-fejlesztés biztonsági rései.

1.1.16 Tartomány-ellenőrző

Mindez elgondolkodtat...

Tudja, hogy a támadók megpróbálják kihasználni a @Apollo tartományaiban található biztonsági réseket, de először meg kell határozni, hogy melyek ezek a tartományok.

Ki tudod fejezni az alábbi mondatokat úgy, hogy kiválasztod a megfelelő kifejezést az egyes legördülő menükből?

Ha minden döntést megtett, válassza a Küldés lehetőséget.

Alkalmazottak

elektronikus személyi igazolvánnyal beléphet a @Apollo irodákba

. Asztali számítógépet, laptopot, táblagépet vagy okostelefont használnak

Bejelentkezés a @Apollo hálózatába

@Apollo előfizetési díj ellenében hozzáférést biztosít az ügyfeleknek egy központilag üzemeltetett eLearning modulcsomaghoz. Ez egy

szolgáltató, amely

felhőtartomány.

KüldésVisszajelzés megjelenítése

1.1.17 A fenyegetés összetettsége

A szoftveres sebezhetőségek programozási hibák, protokoll sebezhetőségek vagy rendszerhibás konfigurációk következtében következnek be. A kiberbűnözők igyekeznek kihasználni az ilyen sebezhetőségeket, és egyre kifinomultabbak támadási módszereikben.

Görgeessen lejjebb, ha többet szeretne megtudni ezek közül.



A fejlett állandó fenyegetés (APT) egy folyamatos támadás, amely több szereplő és/vagy kifinomult rosszindulatú programok bevonásával bonyolult kémkedési taktikákat alkalmaz a célpont hálózatához való hozzáféréshez és annak elemzéséhez.

A támadók a radar alatt működnek, és hosszú ideig észrevétlenek maradnak, ami pusztító következményekkel járhat. Az APT-k általában kormányokat és magas szintű szervezeteket céloznak meg, és általában jól megszervezettek és jól finanszírozottak.

Ahogy a neve is sugallja, az algoritmustámadások kihasználják a legitim szoftverek algoritmusait, hogy nem kívánt viselkedést generáljanak. Például a számítógép energiafogyasztásának nyomon követésére és jelentésére használt algoritmusok felhasználhatók célpontok kiválasztására vagy téves riasztások kiváltására. Letilthatják a számítógépet úgy is, hogy arra kényszerítik, hogy használja fel az összes RAM-ját, vagy túlterhelik a központi feldolgozó egységet (CPU).





1.1.18 Avatar

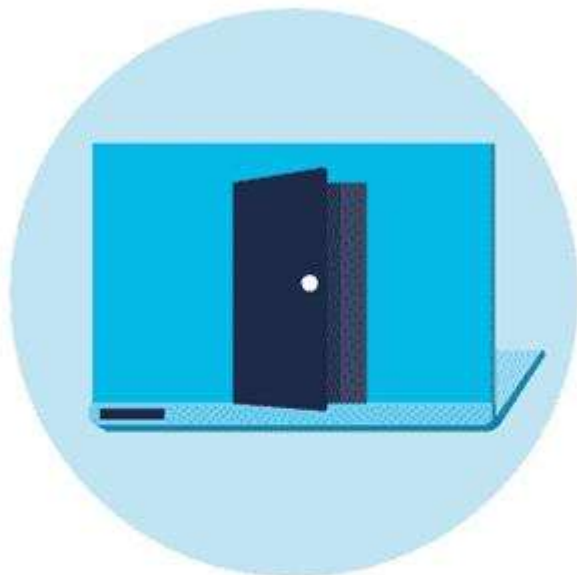
Számos szervezet a fenyegetésfelderítési adatokra támaszkodik, hogy segítsen megérteni az általános kockázatot, hogy hatékony megelőző és reagálási intézkedéseket fogalmazhassanak meg és vezessenek be.

Ezen adatok egy része zárt forráskódú, és a hozzáféréshez fizetős előfizetés szükséges. Más adatok nyílt forráskódú intelligenciának (OSINT) minősülnek, és nyilvánosan elérhető információforrásokból érhetők el. Valójában a fenyegetés-felderítési adatok megosztása egyre népszerűbb, a kormányok, az egyetemek, az egészségügyi szektor szervezetei és a magánvállalkozások együttműködnek mindenki biztonságának javítása érdekében.

1.1.19 Hátsó ajtók és rootkitek

A kiberbűnözők számos különböző típusú rosszindulatú szoftvert (más néven rosszindulatú programot) is használnak támadásaik végrehajtásához.

Válassza ki a képeket, ha többet szeretne megtudni néhány gyakori típusról.



BACKDOORS

touch_app

A kiberbűnözők olyan hátsó ajtóprogramokat, mint a Netbus és a Back Orifice, arra használják, hogy a normál hitelesítési eljárások megkerülésével jogosulatlanul hozzáférjenek a rendszerhez.

A kiberbűnözők általában felhatalmazott felhasználókkal rendelkeznek, akik tudtukon kívül futtatnak egy távoli felügyeleti eszközprogramot (RAT) a gépükön, hogy olyan hátsó ajtót telepítsenek, amely a bűnözői adminisztrátori ellenőrzést biztosítja a célszámítógép felett. A hátsó ajtók folyamatos hozzáférést biztosítanak a kiberbűnözőknek a rendszerhez, még akkor is, ha a szervezet kijavította a rendszer megtámadásához használt eredeti sebezhetőséget.

visszajátszás



ROOTKITS

touch_app

Ezt a rosszindulatú programot úgy tervezték, hogy módosítsa az operációs rendszert, hogy hátsó ajtót hozzon létre, amelyet a támadók ezután távolról elérhetnek a számítógéphez.

A legtöbb rootkit kihasználja a szoftver biztonsági réseit, hogy hozzáférjen olyan erőforrásokhoz, amelyeknek általában nem kellene elérhetőnek lenniük (jogosultságok eskalációja), és módosítja a rendszerfájlokat.

A rootkitek módosíthatják a rendszer kriminalisztikáját és a felügyeleti eszközöket is, így nagyon nehéz észlelni őket. A legtöbb esetben a rootkittel fertőzött számítógépet törölni kell, és újra kell telepíteni a szükséges szoftvereket.

visszajátszás

1.1.20 Fenyegetésekkel kapcsolatos felderítési és kutatási források

Az Egyesült Államok Számítógépes Vészhelyzeti Készenléti Csoportja (US-CERT) és az Egyesült Államok Belbiztonsági Minisztériuma szponzorálja a gyakori sebezhetőségek és kitettségek szótárát (CVE).

Minden CVE-bejegyzés tartalmaz egy szabványos azonosítószámot, a biztonsági rés rövid leírását, valamint a kapcsolódó biztonsági részjelentésekre mutató fontos hivatkozásokat. A CVE-listát egy nonprofit szervezet, a MITRE Corporation tartja fenn nyilvános weboldalán.

A nyilak kiválasztásával többet is megtudhat más fenyegetésfelderítési forrásokról.





**CYBERSECURITY
& INFRASTRUCTURE
SECURITY AGENCY**



Következő...

Ha egy kiberbűnöző megérti egy eszköz, rendszer vagy hálózat sebezhetőségét, mindent megtesz a potenciális áldozatok megtévesztése és az érzékeny információkhoz való hozzáférés érdekében.

Egy alkalmazott
tudtán kívül kapcsolódik
fertőzött USB-t a
Munkahelyi laptop

Egy alkalmazott rákattintott
gyanús e-mail link

Alkalmazott
valaki illetéktelen
fizikai hozzáférés
@Apollo főhadiszállása

Egy korábbi alkalmazott
letölthető
ügyféléjlek
távoli hozzáférés
@Apollo hálózata

Egy alkalmazott belépett
Téves információ
a @Apollo
adatbázis

Szoftver mint szolgáltatás (SaaS)

Ez egy előfizetési modell, amely olyan szoftvert biztosít a szervezetek számára, amelyeket a felhasználók központilag üzemeltetnek és érnek el egy webböngészőn, alkalmazáson vagy más szoftveren keresztül. Más szóval, ez egy olyan szoftver, amelyet nem helyben, hanem a felhőben tárolnak.

Szolgáltatásként nyújtott platform (PaaS)

Ez az előfizetés-alapú modell olyan platformot biztosít, amely lehetővé teszi a szervezet számára, hogy alkalmazásait a szolgáltatás hardverén fejlessze, futtassa és kezelje a szolgáltatás által biztosított eszközök használatával. Ez a platform a nyilvános felhőn keresztül érhető el.

Infrastruktúra mint szolgáltatás (IaaS)

Ez az előfizetés-alapú modell virtuális számítási erőforrásokat, például hardvert, szoftvert, kiszolgálókat, tárolót és egyéb infrastruktúra-összetevőket biztosít az interneten keresztül. A szervezet hozzáférést vásárol hozzájuk, és a nyilvános felhőn keresztül használja őket.

A sötét web

Ez olyan titkosított webes tartalomra vonatkozik, amelyet a hagyományos keresőmotorok nem indexelnek, és amelyhez speciális szoftverre, engedélyre vagy konfigurációra van szükség. Szakértő kutatók figyelik a sötét webet az új fenyegetések felderítése után.

A kompromisszum mutatója (NOB)

Az IOC-k, például a rosszindulatú programok aláírási vagy a domain nevek bizonyítékot szolgáltatnak a biztonsági rések megsértésére és azok részleteire.

Automatizált indikátormegosztás (AIS)

Az Automated Indicator Sharing (AIS), a Kiberbiztonsági és Infrastruktúra-biztonsági Ügynökség (CISA) képessége, lehetővé teszi a kiberbiztonsági fenyegetési mutatók valós idejű cseréjét a strukturált fenyegetési információkifejezés (STIX) és a hírszerzési információk megbízható automatizált cseréje (TAXII) nevű szabványosított és strukturált nyelv használatával.